שאלה 1

בהנתן מערכת עם 100 משתמשים, 10,000 קבצים, והרשאות מתאימות הנתונות במטריצת גישה:

1. האם תמיד קיים מודל BLP המתאר את המערכת?
   אם כן, תארו מודל זה בקווים כלליים. אם לא, הסבירו מדוע (או הראו דוגמה נגדית).
2. האם בכל מקרה ניתן לתאר את המערכת על ידי ACLs?
   אם כן, כתבו כמה ACLs נדרשים. אם לא, הסבירו מדוע.
3. האם בכל מקרה ניתן לתאר את המערכת ע"י Capabilities?
   אם כן, כתבו כמה C-Lists נדרשים. אם לא, הסבירו מדוע.
4. האם בכל מקרה ניתן לתאר את המערכת ב-UNIX קלאסי (9 ביטים)?
   אם כן, הסבירו כיצד. אם לא, הסבירו מדוע.
5. האם בכל מקרה ניתן לתאר את המערכת ב-Windows?
   אם כן, הסבירו כיצד. אם לא, הסבירו מדוע.
6. האם בכל מקרה ניתן יהיה ליצור ערוץ נסתר במערכת?
   אם כן, תנו דוגמה. אם לא, הסבירו מדוע.
7. נניח שניתן לשמור פקודות לשינוי המטריצה (כגון פקודה לשינוי הרשאות) בקובץ הרצה, אשר מורץ בהרשאות של הבעלים.

   א. איזה מנגנון ב-UNIX מאפשר הרצה בהרשאות הבעלים?

   ב. מה הסכנה בנתינת הרשאת כתיבה <u>וגם</u> הרשאת הרצה לקובץ שכזה?

המשך הבחינה בעמוד הבא

Scanned with CamScanner

שאלה 2

פרוטוקול הבא מאמת את זהות המשתמש באמצעות סיסמה חד פעמית.

נסמן: $f^n(x)=f(f(f(\ldots f(x)\ldots)))$ הפעלה של הפונקציה n פעמים, כאשר f היא פונקציית hash קריפטוגרפית.

נגדיר: עבור s ו-n כלשהם, ניתן לחשב n סיסמאות p_i באופן הבא: $p_i = f^{n-i}(s)$ לכל $i = 1,\ldots,n$.

במסגרת הפרוטוקול, בכניסה ה-i יידרש הלקוח להכניס את הסיסמא החד פעמית p_i.

להלן פרטי הפרוטוקול:

אתחול:

- הלקוח בוחר סוד s ומספר n ושולח לשרת בצורה מאובטחת (פגישה פיזית) את $p_0 = f^n(s)$
- השרת מאתחל שני משתנים:
  1. $p = p_0$ אשר מחזיק את הסיסמה האחרונה שהלקוח הזין בהתחברות מוצלחת
  2. $i = 0$ אשר מחזיק את מספר הכניסות המוצלחות של הלקוח

שימו לב: השרת אינו יודע את ערכו של s, אשר נשמר בסוד אצל הלקוח.

בכל כניסה למערכת (לאחר שלב האתחול) מתבצע התהליך הבא:

- השרת שולח ללקוח את i+1
- הלקוח שולח לשרת את הסיסמה $p_{i+1} = f^{n-(i+1)}(s)$
- השרת מעדכן את p ו-i

כאשר i מגיע ל-n-1 מאתחלים את הפרוטוקול מחדש.

ענו על השאלות הבאות:

1. כיצד השרת מעדכן המשתנים שהוא שומר בכל שלב?
2. כיצד השרת מאמת את הסיסמה של הלקוח בכל שלב?
3. כאמור, f היא פונקציית hash קריפטוגרפית. בהינתן p_i מדוע תוקף לא יכול לחשב את p_{i+1}? הסבירו.
4. האם הפרוטוקול פגיע להתקפת שידור חוזר? הסבירו.
5. האם הפרוטוקול פגיע להתקפת האיש שבאמצע?
6. האם הפרוטוקול פגיע לחשיפת קובץ הסיסמאות (כלומר, חשיפה של המשתנים של הסבירו.
7. נניח שהמשתמש בחר את אותה סיסמה על שני מחשבים שונים, נסמנם A ו-B, כאש
   - n שונה בין שני המחשבים (למשל, במחשב A נקבע n = 1000 ובמחשב B נקבע 700
   - שני המחשבים משתמשים באותה פונקציית תמצות קריפטוגרפית f.

   האם הפרוטוקול בטוח?

Scanned with CamScanner

שאלה 3

כתבו נכון/לא נכון. יש להסביר **בקצרה** את תשובותיכם (2-3 משפטים).

א. השורה הבאה חשופה ל-Sql Injection:

var Query = "select * from OrdersTable where ShipCity = ' " + ShipCity + " ' ";

ב. מדיניות RBAC מתאימה רק ב-Discretionary Access Control.

ג. אם קיים מודל BLP למערכת נתונה, אז מובטח שאין ערוץ נסתר במערכת.

ד. ניתן לתכנן תולעת כך שתתפשט בקצב אקספוננציאלי החל מרגע הפעלתה.

ה. אם נגנבו המפתחות הפרטיים של google אז אין דרך לעדכן את הדפדפן שלא יקבל את התעודה של האתר.

ו. יש טעם בשימוש ב-IDS ביחד עם Firewall.

ז. פגיעה במנגנון הרנדומיזציה של המערכת יכול לגרום לעקיפת מנגנון הקנרית.

ח. תהי H פונק' Hash קריפטוגרפית טובה המייצרת פלט באורך 256 ביטים, אזי קשה למצוא x המקיים H(x)<1000.

ט. בהינתן מספר גדול (2000 ביטים ומעלה) החלטה אם מספר זה פריק (כלומר לא ראשוני) היא בעיה קשה (כלומר לא ידוע על אלג' שיבצע פעולה זו בזמן סביר).

י. בהינתן מספר פריק (כלומר לא ראשוני) גדול (2000 ביטים ומעלה) מציאת הגורמים הראשוניים שלו היא בעיה קלה (כלומר קיים אלג' שיבצע פעולה זו בזמן סביר).

שאלה 4

הסבירו חמישה מתוך ששת המושגים הבאים. יש ללוות בדוגמה כשמתאים.

1. MAC (Massage Authentication Code)
2. Least Privilege
3. XSS
4. Stream cipher זה אמצעי לבקרת סימטרי לפי אורך משפיע על
5. IDS
6. Challenge response

המשך הבחינה בע

Scanned with CamScanner

שאלה 5

א. (8 נק') באיזה תנאים פרוטוקול קרברוס חשוף להתקפת אופליין על סיסמת המשתמש? מדוע פרוטוקול SSL לא חשוף להתקפה זו?

ב. (10 נק') כידוע במהלך ביצוע שלב ההתקשרות הראשונית (Handshake) בפרוטוקול SSL (TLS) בין לקוח ושרת, הלקוח יכול לשלוח לשרת מפתח שהוא ייצר בעצמו, או לייצר אותו בצורה משותפת עם השרת על ידי שימוש בפרוטוקול DH. הסבירו את היתרונות והחסרונות של אפשרויות אלו. התייחסו גם לאפשרות התקפת האיש שבאמצע.

ג. (7 נק') תנו דוגמה לקוד עם לפחות פגיעות Buffer Overflow אחת **שלא ניתן לפתור** באף אחת משיטות ההגנה הבאות (ואף לא בשילוב של חלקן/כולן):

שתילת ערך לפני כתובת החזרה בזמן קומפילציה - CANARY

סימון מחסנית כ "לא להרצה" - DEP (NX)

רנדומיזציה של מיקומי פונקציות מערכת ידועות - ASLR

הסבירו את תשובתכם.

כיצד בכל זאת ניתן למגר פגיעויות מסוג זה?

ב ה צ ל ח ה !

Scanned with CamScanner